

Server-Side Request Forgery (SSRF) Candidate

Assessment Identifier: **WS-STA-07** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: HIGH	CVSS: 8.1	CWE: CWE-918
OWASP: A10	WASC ID: N/A	Confidence: High candidate
Target / Component: src/App.ts / map components / server-side request handling	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/src/App.ts	Parameter: Server proxy URL parameter

1. Description

Static analysis identified dynamic URL/request handling that may potentially allow user-controlled URLs to be requested by the server. Exploitability requires confirmation that an untrusted input reaches a server-side request sink.

2. Steps to Reproduce

1. Identify the server-side request function.
2. Trace its URL source.
3. Determine whether the URL is user-controlled.
4. Use a local HTTP test server.
5. Confirm whether the application's server makes the request.

3. Controlled Proof of Concept

Safe Proof of Concept:
 Use only a local endpoint such as http://127.0.0.1:8000/test that you control. Do not probe cloud metadata endpoints, internal networks, or third-party systems.

4. Business & Security Impact

If confirmed, SSRF could allow requests from the application's network environment to resources inaccessible directly from the Internet.

5. Remediation Recommendations

Primary Fix: Allowlist destinations and schemes, validate hostnames/IPs, block private/internal ranges where appropriate, restrict outbound network access, and avoid arbitrary client-supplied URLs.

1. Enforce strict destination allowlisting for external API endpoints.
2. Validate resolved IP addresses to block RFC1918 private ranges and cloud metadata services (169.254.169.254).
3. Disable HTTP redirection following in server-side HTTP client instances.

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis
 This finding was identified through static analysis of repository source code and configuration files. Per assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*